OutOfRole in Plain Words

The Debugging Table · IBM Z Datathon 2026 · AI Secured: Innovation Without Exposure

In one paragraph

OutOfRole compares each employee's recent activity with their own normal weeks, and gives security analysts a short daily review list of 20 names. A Netflix-style recommender also learns which computers each person normally uses, and a periodic snooping review counts the weeks in which someone logged into computers outside their profile. For each person on the list, it gathers the evidence that is new to that person and rare in the company. In the LinuxONE build, IBM Granite will pick a summary label from a fixed list and the facts that support it. Granite writes no free text: code writes every fact sentence, always shows the top-ranked evidence, and rejects any reply that breaks the rules. Separately, a Netflix-style recommender predicts which websites each person will use next, so routine access can be pre-approved, and websites people stopped using become suggestions for access review. Processing and AI stay on the one server, and people appear only as pseudonyms.

The problem

Some people misuse access they legitimately have. They copy files to a USB stick before quitting, upload documents to a leak site, or log into colleagues' computers to snoop. Valid logins can hide this misuse, and analysts need a short list they can actually review.

What OutOfRole does

1. **Watch.** Every day, compare each person's last 7 days with every one of their normal weeks from training: USB connections, file copies, after-hours activity, and the number of computers used. When an activity beats all their normal weeks, their score rises. The 20 highest scores form the day's review list. A separate snooping review uses the recommender. It counts the weeks in which a person logged into computers absent from their training history and scored below our chosen recommendation threshold, discounting people who always roam. It works as an end-of-period review; as a live list it adds nothing to the daily list.
2. **Explain.** For each name on the list, rank what they did: things not seen in their training history first, then the rarest in the company. Granite replies with only a label from a fixed list and the IDs of the facts behind it. Code renders each fact from the data and always shows the top 3 ranked items. Any other reply is rejected, and a plain fallback is shown instead.
3. **Prevent.** The recommender learns which websites each person uses and predicts the ones they will want next. Those can be pre-approved; anything else goes to a reviewer. Sites no one in the company visited during the training months are blocked. At the end of a review period, websites a person used in training but not since become access-review suggestions. CERT has no real permission lists, so past use stands in for held access.

What we measured

The data is the CERT insider-threat benchmark, in two releases. r4.2 has 1,000 staff and 70 insiders; r5.2 has 2,000 staff and 99 insiders. The method behind the daily list was chosen after exploratory testing. Build metrics come from one program, `outofrole_minimal.py`; the historical controls (chance, the method we named in advance) come from the experiment scripts.

Step	Result	r4.2	r5.2
Watch	Insiders on the daily list before their last malicious action	59 of 70	**80 of 99**
	Same, standard 28-day baseline, also 20 names a day	59 of 70	40 of 99
	Share of each insider's malicious actions on later days (all insiders, missed = 0)	54%	48%
	Normal staff ever placed on the list over the test period	230 of 930	291 of 1,901
	Snoopers in the top 100 of the end-of-period snooping review (without the recommender in brackets)	no snoopers in r4.2	27 of 30 (26)
	Same review run as a live 10-name daily list: snoopers caught in time (the daily list alone catches 25)	no snoopers	9 of 30
Explain	Insiders caught in time whose top 3 ranked evidence items (before Granite) include an activity matching the answer key	64%	85%
	Same, ranking by rarity alone	49%	51%
	Strong evidence at first alert, insiders vs normal staff (no labels used)	29% vs 18%	65% vs 31%
Prevent	Next new websites caught by the recommender's top 20 (popularity in brackets)	21% (14.5%)	19% (13%)
	Access requests per person per month: own history only, then with the recommender	2.31 to 1.82	3.15 to 2.55
	Websites used in training but not again (access-review suggestions)	6.0%	3.6%
	Wikileaks and keylogger-site visits blocked by the new-to-company rule	100%	100%

What this means:

- **In the r5.2 replay, the daily list catches twice as many insiders as the standard baseline.** Both lists hold 20 names a day, though ours changes a little faster (11.3% vs 8.9% of names a day). On r4.2 the two tie.
- **The daily warning list uses personal history; the recommender supports a separate snooping review and website access advice.** It predicts which websites people will use next better than popularity does.

How simple it is

Spark turns the raw logs into three tables. Everything else is two short Python files:

- `outofrole_minimal.py` (252 lines, about 20 seconds per release on a laptop): the daily list, the evidence ranking, the recommender (snooping view and access advice), the access suggestions and the block rule.
- `case_file.py` (85 lines): the evidence pack, the Granite prompt, the reply check and the plain fallback. Its self-test feeds in 12 bad replies (free-text notes with a made-up name or quantity, unknown or malformed fact IDs, a label outside the list, non-JSON text); all 12 fall back without crashing.

Granite and a small dashboard sit on top.

How it connects to our proposal

We promised	We deliver
Catch insiders with valid logins without flooding analysts	A 20-name daily list
"A recommender that catches insider snooping" (our title)	The end-of-period snooping review puts 27 of 30 snoopers in its top 100 (26 without the recommender); live warnings come from the daily list, which catches 25 of 30 snoopers in time (r5.2)

We promised	We deliver
"Learns which files and machines each employee normally uses"	The recommender learns each person's computers and websites; the daily list learns each person's normal weeks. Files could not be modelled: in CERT, 100% (r4.2) and 94% (r5.2) of file names belong to one person, so there is nothing to learn
"Access it would never suggest is flagged"	Computers: weeks with logins below the recommendation threshold feed the snooping review. Websites: recommended access is pre-approved, anything else goes to review, never-seen sites are blocked
"An AI on the same server explains why"	Granite labels each case and picks the supporting facts; code renders them; all on LinuxONE (built at the event)
Analysts: a short, ranked list of explained alerts	The daily list plus case files
Compliance: a record of who accessed what and why	Each case file lists dated, cited evidence items
Access admins: permissions held but never used	Access-review suggestions from past use (6.0% and 3.6% of websites), plus pre-approval suggestions
Data never leaves the platform	One server, pseudonyms only
Spark matrix, ALS on early months, later months replayed as a live stream	Spark builds the tables and ALS trains on the early months. Daily warnings replay the later days; the snooping review summarizes the period

What changed: personal history drives the broader daily warning list. The exploratory snooping review finds 27 of 30 snoopers, against 26 without the recommender, using the same weekly counting and roaming adjustment; it was designed after examining r5.2 and has no untouched test. The website recommender supports access advice. Files were not modelled, because CERT file names are almost all unique to one person.

What we say openly

- CERT is synthetic data. These are replay results, not a live deployment.
- The method behind the daily list was chosen after seeing results. The method we had named in advance also beat the baseline (54 vs 28 of 99).
- Evidence is graded on the day each insider was caught in time, and measures the evidence ranking before Granite. Among insiders ever listed, 46% (r4.2) and 31% (r5.2) were first listed before their labelled attack began, when there was no labelled malicious activity to cite yet.
- Two-day sysadmin sabotage is mostly missed.
- The snooping review was designed after looking at r5.2 and has no untouched test. As a live list it catches only 9 of 30 snoopers in time.
- Granite and the LinuxONE run are built at the event. The code they plug into is tested here.

Every number above, with the script that produced it, is in `feasibility/Verified_Numbers.md`.